
Web Application Penetration Test Report — v1.0

Target System: OWASP Juice Shop

Performed by the OpenHack Security Agent

Issued by Security Lead (lead@example.com)

2026-02-20

Contents

1	Document Control	2
2	Executive Summary	3
3	Execution of the Security Penetration Test	5
3.1	Subject Under Test	5
3.2	Scope	5
3.3	Methodology	5
3.4	Events	6
4	Risk Assessment	7
4.1	CVSS	7
4.2	Risk Categories	8
4.3	Vulnerability States	9
5	Summary of Findings	10
6	Findings and Remediation	11
6.1	Finding	11
6.1.1	SQL Injection Authentication Bypass in Login Endpoint	11
6.2	Finding	12
6.2.1	JWT Public Key Information Disclosure	12
7	Appendix A - Lists, Scripts and Raw Data	14
8	Appendix B - List of Abbreviations	15

Scope

Security Consulting Inc was engaged by Jane Smith to conduct Web Application Security Assessment IT security investigation. The subject of the investigation was the “OWASP Juice Shop”.

The test was performed using Local development environment (Docker).

Objective

The objective of the IT security investigation was to identify vulnerabilities and security gaps which, in the event of misuse, would have an impact on the availability, integrity and confidentiality of the defined applications and/or systems and the data processed on them. The result of this project is a report that contains a management summary of all relevant findings and a compilation of recommended measures.

The technical IT security audit is not a substantive audit effort to ensure that all vulnerabilities and security gaps existing at the time of the audit are identified. There is a possibility that established safeguards will effectively prevent identification and exploitation of vulnerabilities and security gaps. The client acknowledges that this is not an indicator of deficiencies in engagement performance and that additional unidentified vulnerabilities and security gaps may exist.

Disclaimer

‘Security Consulting Inc’ conducted the security penetration test on behalf of ‘Jane Smith’. This report has been prepared exclusively for ‘Jane Smith’. It is intended exclusively for internal use and is accordingly not designed to serve third parties as a basis for their decisions, unless agreed otherwise in writing. Third parties may not derive any rights or otherwise benefit from this engagement unless agreed otherwise in writing. Affiliated companies of the client are also considered “third parties” within the meaning of this engagement.

‘Security Consulting Inc’ does not assume any liability or legal claims against third parties unless agreed otherwise in writing or a disclaimer cannot effectively be implemented.

It is the sole responsibility of anyone who becomes aware of the work results summarized in this report to decide to what extent and in what way the information is useful or appropriate and to supplement, check or update it as part of their own review.

No adjustments will be made to the report to reflect events or circumstances that occur after the report is issued, unless required by law.

The recommendations in this report are general and applicable in many different environments but could have unpredictable effects in specific environments. Therefore, any actions derived from the recommendations should be carefully considered and implemented through the regular change process. This should include appropriate testing of the changes on a test environment prior to going live. If the changes are not tested in advance in an identically configured test environment, failures or other damage cannot be ruled out.

Please note: Technical descriptions (or parts thereof) in this report may be taken from the OWASP Testing Guide (www.owasp.org).

1 Document Control

Document Status

Title	Security Assessment Report
Document Owner	Security Consulting Inc
Classification	Strictly Confidential
Project Timeframe	2026-02-20

Version History

Version	Date	State	Author	Comments
0.1	2026-02-20	Draft	Security Lead	–
1.0	2026-02-20	Final document	Security Lead	–

Contact Persons - Assessor

Name	Role	Phone	Email
Security Lead	Lead Penetration Tester	+1-555-0100	lead@example.com

Contact Persons - Client

Name	Role	Phone	Email
Jane Smith	Security Lead	+1 555 987 6543	jane.smith@acme.com

2 Executive Summary

Security Consulting Inc (hereinafter referred to as “ASSESSOR”) has been commissioned by Jane Smith (hereinafter referred to as “CLIENT”) to carry out a penetration test.

The penetration test of the OWASP Juice Shop application took place on **2026-02-20**.

For this purpose, the web application, accessible at <http://localhost:3333>, was tested from the perspective of an external attacker.

Two security vulnerabilities were identified during the assessment:

1. **Critical SQL Injection (CVSS 9.8):** The login endpoint at `/rest/user/login` is vulnerable to SQL injection, allowing complete authentication bypass and unauthorized access to administrative accounts.
2. **Medium JWT Information Disclosure (CVSS 5.3):** Cryptographic material including the JWT public key and premium license key are exposed through unprotected endpoints, potentially enabling further attacks against the authentication mechanism.

Both vulnerabilities have been confirmed and documented with proof-of-concept exploits and remediation recommendations.

Critical: **1** | High: **0** | Medium: **1** | Low: **0** | Informational: **0** | Total: **2**

Table 2.1: Overview of Findings

Severity Count	
Critical	1
High	0
Medium	1
Low	0
Informational	0
Total	2

A description of the scope and test environment can be found in Chapter 3. Chapter 4 presents

the risk assessment methodology. Chapter 5 provides a summary of findings. Chapter 6 contains the detailed technical descriptions of the findings including remediation measures.

It is recommended that the remediation of the critical risk vulnerabilities be treated with the highest priority and countermeasures implemented as soon as possible. The vulnerabilities with high and medium risk should also be remedied in the short term. The low-risk vulnerabilities should be treated with lower priority due to their reduced risk, but should still be addressed.

DRAFT

3 Execution of the Security Penetration Test

3.1 Subject Under Test

OWASP Juice Shop is a modern insecure web application designed for security testing and training. The application contains numerous vulnerabilities including authentication issues, injection flaws, and cryptographic weaknesses.

3.2 Scope

The scope for the assessment was the following targets:

- Primary: `http://localhost:3333`
- Web application and REST API endpoints
- Authentication and session management
- Database interaction points

3.3 Methodology

The security penetration test of the OWASP Juice Shop took place on 2026-02-20.

Testing was conducted using a combination of automated scanning and manual verification. The assessment focused on identifying high-impact vulnerabilities including SQL injection and JWT weaknesses as requested.

The web application was tested for security vulnerabilities across the following categories. This can be considered a guideline as penetration tests are a creative process and therefore the tests are not limited to what is given here. The base of these categories is the OWASP Top 10 for Web, which is fully covered by this penetration test approach.

Category	Description
Broken Access Control	Users can act outside their permissions, leading to unauthorized viewing, modification, or deletion of data.

Category	Description
Security Misconfiguration	Systems or cloud services are insecurely configured, e.g., through default passwords or unnecessarily enabled features.
Software Supply Chain Failures	Vulnerabilities arise from compromised third-party code, libraries, or build pipelines.
Cryptographic Failures	Sensitive data is exposed through missing, weak, or incorrectly implemented encryption.
Injection	Attackers inject malicious commands (e.g., SQL or shell code) through input fields that the system erroneously executes.
Insecure Design	Fundamental architectural flaws that exist before implementation make an application inherently insecure.
Authentication Failures	Flaws in identity verification allow attackers to take over sessions or guess passwords (brute force).
Software or Data Integrity Failures	Lack of verification of code or data sources leads to acceptance of untrusted updates or serialization data.
Security Logging & Alerting Failures	Attacks go undetected or responses are delayed due to missing logs or absent alert notifications.
Mishandling of Exceptional Conditions	Programs respond inadequately to unforeseen situations, which can lead to crashes or logic errors.

3.4 Events

During the test, the following restrictions or events occurred that may have affected the scope or depth of the assessment:

4 Risk Assessment

4.1 CVSS

The risk assessment of the vulnerabilities found is performed using the industry standard Common Vulnerability Scoring System v4.0 (hereinafter referred to as “CVSS”). This is a standard that can be used to uniformly assess the vulnerability of computer systems and the severity of security vulnerabilities. This makes it possible to compare vulnerabilities more effectively.

The Common Vulnerability Scoring System has a metric structure and is based on values that are divided into four groups: “Base”, “Threat”, “Environmental” and “Supplemental”. To determine the vulnerability scores, each group has its own rules. The values of the Base group are invariant in time and remain the same in different environments. In the Threat group, the time dependency of a vulnerability is taken into account. For example, the vulnerability of a system to a particular vulnerability decreases over time as more and more countermeasures such as patches become known and available. The Environmental group incorporates various criteria of the specific IT environments into the vulnerability rating. The Supplemental group provides additional context that does not modify the final score.

The CVSS ratings are numerical values on a scale of 0.0 to 10.0, with the highest vulnerability of a system occurring at a value of 10.0. Our rating is based on the CVSS-B (Base Score) and is composed of:

- Attack Vector (AV)
- Attack Complexity (AC)
- Attack Requirements (AT)
- Privileges Required (PR)
- User Interaction (UI)
- Vulnerable System Impact: Confidentiality (VC), Integrity (VI), Availability (VA)
- Subsequent System Impact: Confidentiality (SC), Integrity (SI), Availability (SA)

As penetration testers, we can only assess the general threats posed by a vulnerability (CVSS-B). However, we have no insight into the internal structures of our clients. Therefore, the assessment of the specific risks for the client’s systems and business processes must be done by the client. For this purpose, CVSS offers the Environmental metrics (CVSS-BE). This makes it possible to subsequently adjust the CVSS score of vulnerabilities after the test result has been submitted before they are remedied. This changes the assessment of the risk and thus

the urgency of remediation of a vulnerability. For more information, see [CVSS v4.0 Specification](#).

4.2 Risk Categories

The risk categories used in this report reflect the recommended priority for addressing the vulnerabilities identified during the penetration test. The categorization is based on the probability of exploitation and the significance of the impact. The risk value is calculated using the CVSS v4.0 standard:

Assessment	Risk Category Description
Critical	Critical vulnerabilities that allow an attacker to gain full access to the object under test and its sensitive information. It is possible to cause enormous damage to the client's reputation. Furthermore, these vulnerabilities may allow attackers to gain wide-ranging privileges, including to other systems or applications of the client that have not been investigated in detail within the scope of this project. Exploitation of the vulnerabilities is not prevented and can be reproduced with medium to low effort.
High	Vulnerabilities that may allow an attacker to manipulate sensitive data, damage the client's reputation, gain unauthorized access to sensitive information, or gain unauthorized access to applications or the client's infrastructure. The vulnerabilities are reproducible with medium to high effort.
Medium	Vulnerabilities that may allow an attacker to harm the client's reputation or gain unauthorized access to client data. The privileges that an attacker can gain by exploiting the vulnerabilities are limited.
Low	Security vulnerabilities that do not pose a threat in themselves, but which, for example, provide attackers with useful information about the network and systems. These vulnerabilities allow an attacker only very limited access.
Informational	Anomalies such as functional limitations or inconsistencies. These do not currently represent a risk and have no negative impact on the test object. Accordingly, no action is required. Nevertheless, countermeasures can be helpful for the functional and safety improvement of the test object. If necessary, this may give rise to risks under other circumstances.

4.3 Vulnerability States

The vulnerabilities can be in one of the following states:

- **Active:** The vulnerability has been identified and it has been possible to verify its existence through exploitation or direct evidence.
- **Potential:** The vulnerability has been identified but its exploitation has not been possible, so its existence cannot be fully verified, and it is up to the client to determine the impact.
- **Fixed:** The vulnerability has been remediated and verified through retesting.

DRAFT

5 Summary of Findings

Id	Finding Name	Risk Assessment	CVSS v4 Score
01	SQL Injection Authentication Bypass in Login Endpoint	Critical	9.8
02	JWT Public Key Information Disclosure	Medium	5.3

DRAFT

6 Findings and Remediation

6.1 Finding

6.1.1 SQL Injection Authentication Bypass in Login Endpoint

Severity	Critical
CVSS Base Score	9.8 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N)
Assets	http://localhost:3333/rest/user/login
Status	open

Description

The login endpoint at /rest/user/login is vulnerable to SQL injection, allowing attackers to bypass authentication and gain unauthorized access to any user account, including administrative accounts. The vulnerability exists because user-supplied input is directly concatenated into SQL queries without proper sanitization or parameterization.

Vulnerable Endpoint: POST /rest/user/login

Affected Parameter: email (body parameter)

Root Cause: The application constructs SQL queries by directly embedding user input without using parameterized queries or proper escaping, allowing SQL metacharacters to modify query logic.

Proof of Concept

Attack Payload:

```
{  
  "email": "admin@juice-sh.op'--",  
  "password": "anything"  
}
```

Successful Authentication Response:

```
{
  "authentication": {
    "token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9...",
    "bid": 1,
    "umail": "admin@juice-sh.op"
  }
}
```

Decoded JWT Payload showing admin access: - User ID: 1 - Email: admin@juice-sh.op - Role: admin - Password hash exposed: 0192023a7bbd73250516f069df18b500 (MD5)

Remediation

1. **Use Parameterized Queries:** Replace all string concatenation in SQL queries with parameterized queries/prepared statements.
2. **Input Validation:** Implement strict input validation on the email field using regex patterns and whitelist validation.
3. **ORM Security:** Ensure ORM methods (like Sequelize) use proper query builders instead of raw SQL with user input.
4. **Principle of Least Privilege:** Database connections should use accounts with minimal necessary privileges.
5. **Web Application Firewall (WAF):** Deploy a WAF with SQL injection rules as a defense-in-depth measure.

6.2 Finding

6.2.1 JWT Public Key Information Disclosure

Severity	Medium
CVSS Base Score	5.3 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N)
Assets	http://localhost:3333/encryptionkeys/jwt.pub, http://localhost:3333/encryptionkeys/premium.key
Status	open

Description

The application exposes sensitive JWT cryptographic material through the publicly accessible endpoint /encryptionkeys/jwt.pub. This endpoint returns the RSA public key used for JWT signature verification without requiring authentication.

Exposed Asset: <http://localhost:3333/encryptionkeys/jwt.pub>

Impact: While the JWT implementation properly validates signatures, exposing the public key allows attackers to understand the JWT verification mechanism, provides material for attempting algorithm confusion attacks, and reveals implementation details that could aid in further attacks.

Additional Finding: The directory listing at [/encryptionkeys/](#) also exposes a `premium.key` file containing sensitive cryptographic material.

Proof of Concept

Step 1: Access the JWT public key without authentication `curl http://localhost:3333/encryptionkeys/jwt.pub`

Response contains RSA public key used for JWT verification.

Step 2: Directory listing reveals additional keys `curl http://localhost:3333/encryptionkeys/`

Reveals: `jwt.pub`, `premium.key`

Step 3: Access premium key material `curl http://localhost:3333/encryptionkeys/premium.key`

Returns: `1337133713371337.EA99A61D92D2955B1E9285B55BF2AD42`

Remediation

1. Remove Public Key Endpoint: Do not expose cryptographic keys via public HTTP endpoints.
2. Access Control: If keys must be served, implement proper authentication and authorization checks.
3. Directory Listing: Disable directory listing on the `/encryptionkeys/` path.
4. Key Storage: Store cryptographic keys outside the web root or use secure key management services.

7 Appendix A - Lists, Scripts and Raw Data

DRAFT

8 Appendix B - List of Abbreviations

Abbreviation	Description
API	Application Programming Interface
CAPTCHA	Completely Automated Public Turing test to tell Computers and Humans Apart
CVSS	Common Vulnerability Scoring System
FTP	File Transfer Protocol
IDOR	Insecure Direct Object Reference
MD5	Message-Digest Algorithm 5
OAuth	Open Authorization
ORM	Object-Relational Mapping
OWASP	Open Web Application Security Project
PII	Personally Identifiable Information
SQL	Structured Query Language
TOTP	Time-based One-Time Password
URI	Uniform Resource Identifier
WAF	Web Application Firewall

+-----+-----+